Dipartimento di Informatica

AI-Driven Automated Penetration Testing Tools

Analisi comparativa di 6 framework agentici (LLM) in ambiente locale



Studente: Costantino Paciello
Docente: Prof. Arcangelo Castiglione
Anno accademico: 2025-26

Panoramica

01



Evoluzione

Dal determinismo agli Agenti LLM

02



Architettura

I 6 framework a confronto

03



Metodologia

Setup locale e modelli Qwen

04



Risultati

Successi e criticità (tool-calling)

05



Riproducibilità

Istruzioni per il test

06

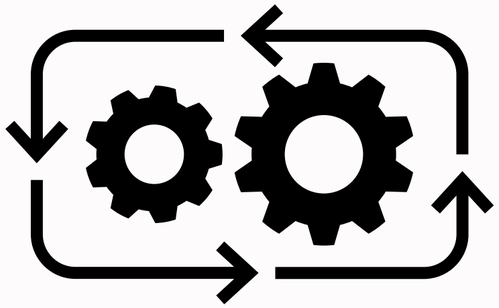


Conclusioni

I limiti dell’autonomia zero-click

Il Contesto: L’Evoluzione del Penetration Testing

Automazione Deterministica



Strumenti classici: Nmap, Nuclei, ZAP

Pro:
- Regole rigide basate su firme.
- Alta prevedibilità.

Contro:
- Assenza di ragionamento contestuale su catene multi-step. Alti falsi positivi.
- Non sono capaci di concatenare debolezze distinte in una catena d'attacco complessa.

Paradigma Agentico LLM



Modelli Linguistici e Agenti

Pro:
- Interpretare output testuali disomogenei
- Formulare ipotesi dinamiche
- Adattare la strategia in base alle risposte del target

Contro:
- Faticano a mantenere la coerenza strategica sull'intero scenario operativo
- Alti falsi positivi/negativi

Il Paradigma Agentico e le Sue Sfide

Il Loop Operativo

Observe
(Percezione dei Log)

Think
(Pianificazione & PTT)

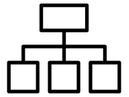
Act
(Esecuzione Comando / Tool-calling)



Rischio: Collasso del Tool-calling

PentestGPT

Pentesting Task Tree (PTT)



Struttura gerarchica per mantenere la memoria di obiettivi e azioni.

Le Sfide Critiche

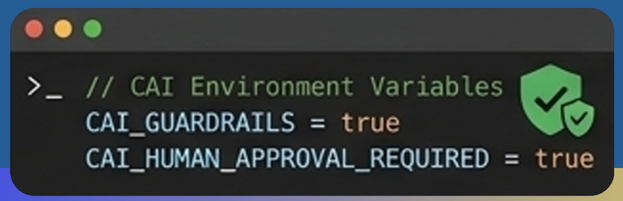


Contextual Forgetting in sessioni lunghe



Allucinazioni: Ipotesi senza riscontri empirici.

Lo Spettro dell’Autonomia: Architettura a Confronto



Copilota Interattivo

PentestGPT, CAI

- L’operatore media, filtra il rumore e autorizza. Previene derive distruttive

Ibrido AI + Scanner

BugTraceAI

- L’AI propone scenari, gli scanner deterministici (es. Nuclei) verificano empiricamente.

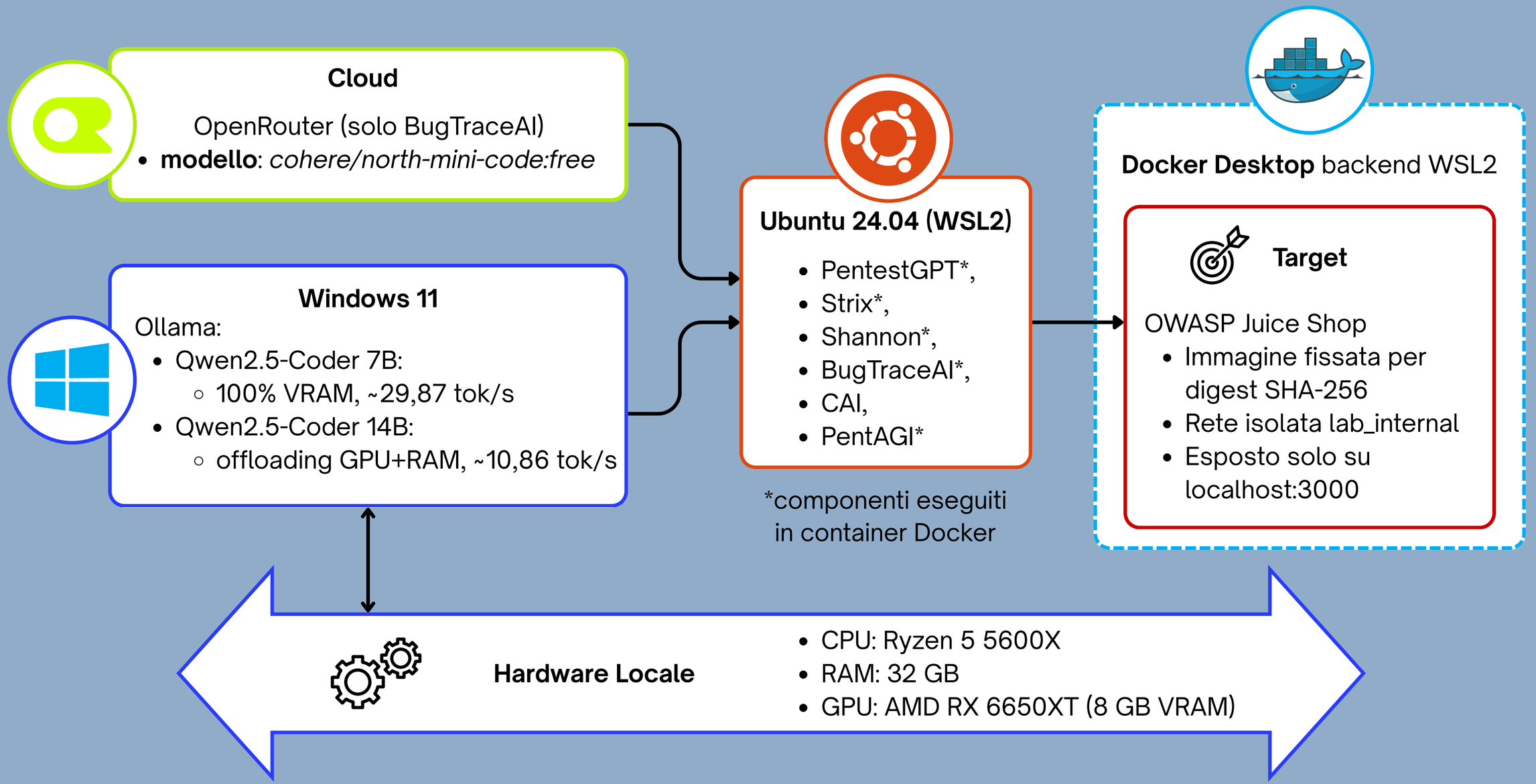
Zero-Click

Strix, Shannon, PentAGI

- Delegano interamente all’LLM l’orchestrazione e il parsion JSON

Il Trade-off: maggiore è l'autonomia richiesta a un modello locale compatto, maggiore diventa la fragilità del sistema e la probabilità di collasso strutturale del protocollo

Metodologia e Configurazione Ambiente



Architettura di Inferenza (Modelli Locali e Cloud)

Confronto tra modelli locali su Ollama

Modello	Allocazione	Throughput	Impatto
Qwen2.5-Coder 7B	100% VRAM GPU	~29,8 token/s	Alta velocità, minore stabilità logica
Qwen2.5-Coder 14B	Offloading Ibrido (GPU + RAM)	~10,8 token/s	Maggiore capacità logica, alta latenza



Eccezione: Architettura Cloud

BugTraceAI testato via API OpenRouter (cohere/north-mini-code:free) a causa di vincoli hard-coded del framework che rigettano i nomi dei modelli locali.

```
>_
GET /config/agents HTTP/1.1
Host: localhost:5000

{
  "primary_agent": "cohere/north-mini-code:free",
  "scanner_agent": "cohere/north-mini-code:free",
  "orchestrator_agent": "cohere/north-mini-code:free"
}
> _
```

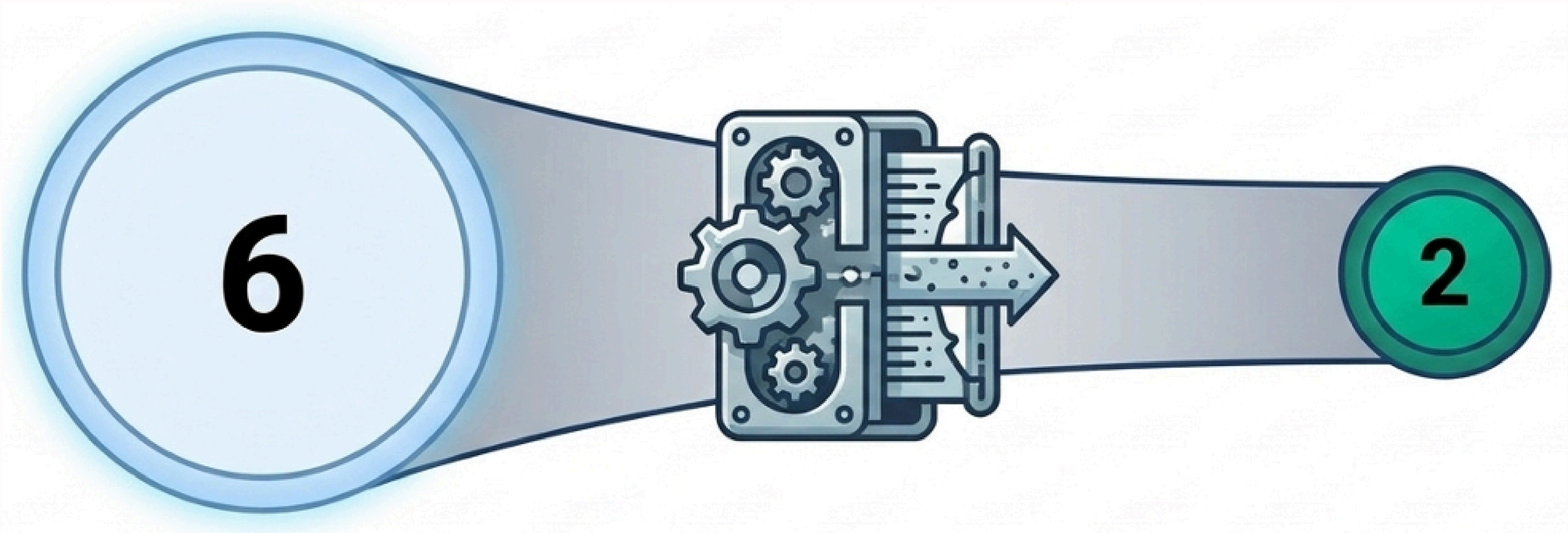
Metriche di Efficacia: Risultati Sperimentali

High-impact Traffic Light Table

Framework	Paradigma	Stato Esecuzione	Finding Validi
BugTraceAI	Ibrido / Cloud	Completata al 100%	2 (0 Falsi Positivi)
CAI	Copilota	Completata (con intervento)	1 (Directory Listing)
PentestGPT	Copilota	Completata (modo guidato)	1 (Info Disclosure)
Strix, PentAGI, Shannon	Fully Autonomous	Interrotta (Crash Orchestratore)	0

NB: l'efficacia operativa attuale è inversamente proporzionale all'autonomia delegata al modello.

I Successi: Il Valore della Validazione (BugTraceAI)



Ipotesi LLM iniziali
(Incluse allucinazioni e falsi positivi)

Filtro Deterministico
(Verifica tramite template Nuclei)

Vulnerabilità Confermate
(Missing Rate Limiting, Security Headers assenti)

Insight Architetturale: L'Intelligenza Artificiale fornisce l'intuizione esplorativa; lo scanner deterministico fornisce la prova inconfutabile, azzerando i falsi positivi nel report finale.

I Successi: Il Paradigma Copilota (CAI & PentestGPT)

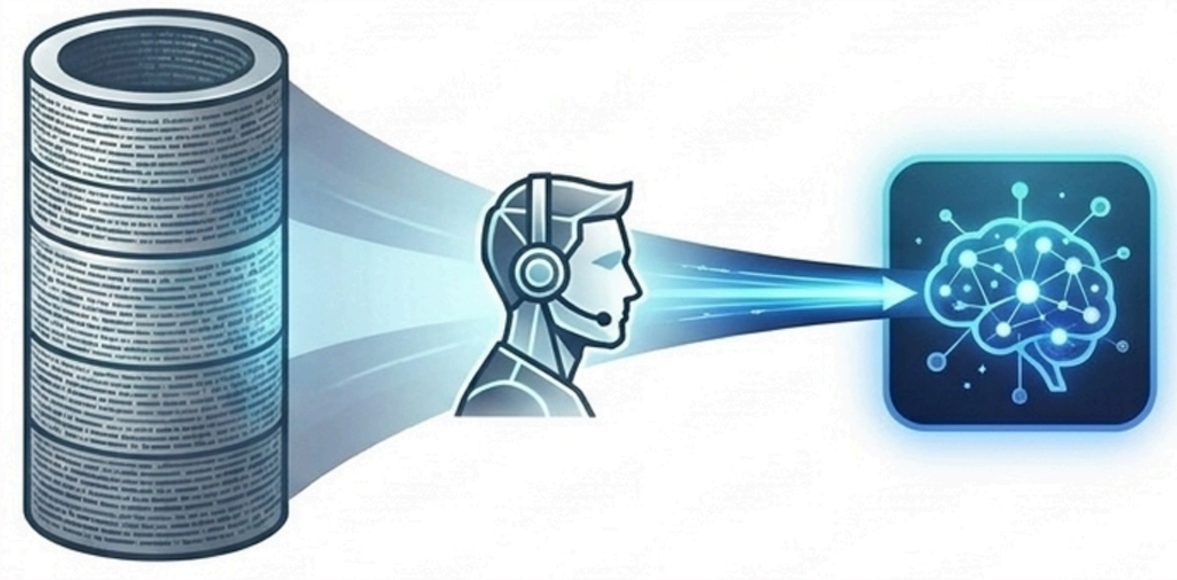
CAI

- **Qwen 14B**: Rileva correttamente /ftp, ma allucina un "pannello admin" dall'header X-Recruiting
- **Qwen 7B**: Rileva /ftp, ma applica etichette in modo discontinuo e genera pseudo-comandi incoerenti.

PentestGPT

- **Qwen 14B**: Catena completata (/ftp → download acquisitions.md). Limite: incapace di generare autonomamente il report Markdown finale.
- **Qwen 7B**: ignora vincoli negativi espliciti ("NON aggiornare il PTT"), introduce refusi e regredisce proponendo task di ricognizione già completati.

Il Collo di Bottiglia del Contesto



Muro di Log Grezzi

Le 3 Vulnerabilità Confermate

Missing Rate Limiting (Endpoint Login)

Framework: BugTraceAI
L'applicazione non impone alcun limite al numero di tentativi di autenticazione consecutivi da un singolo IP o sessione.

Missing Security Headers

Framework: BugTraceAI
Mancano header di sicurezza fondamentali come Content-Security-Policy (CSP), X-Frame-Options o Strict-Transport-Security (HSTS).

Information Disclosure

Framework: CAI e PentestGPT
Il server web ha il "directory listing" abilitato, rendendo pubblicamente visibili e scaricabili file interni.

I Fallimenti: Il Collasso del Tool-Calling

```
[ERROR] orchestrator: got message instead of tool call
[AGENT] reflector: "The system encountered an error.
Please provide the specific command..."
```

PentAGI: Messaggio discorsivo invece della chiamata a funzione strutturata

```
[2026-10-06 17:51:09] [AGENT] ssrf-vuln: Failed (OUTPUT_VALIDATION_FAILED) (10.3s, $0.0000)
[2026-10-06 17:51:19] [AGENT] injection-vuln: Failed (OUTPUT_VALIDATION_FAILED) (20.2s, $0.0000)
[2026-10-06 17:51:29] [AGENT] xss-vuln: Failed (OUTPUT_VALIDATION_FAILED) (30.1s, $0.0000)
[2026-10-06 17:51:39] [AGENT] auth-vuln: Failed (OUTPUT_VALIDATION_FAILED) (40.1s, $0.0000)
[2026-10-06 17:51:49] [AGENT] authz-vuln: Failed (OUTPUT_VALIDATION_FAILED) (50.3s, $0.0000)
```

Shannon: Mancata emissione dello schema PoC atteso -> Blocco iterativo

PentAGI - Shannon - Strix

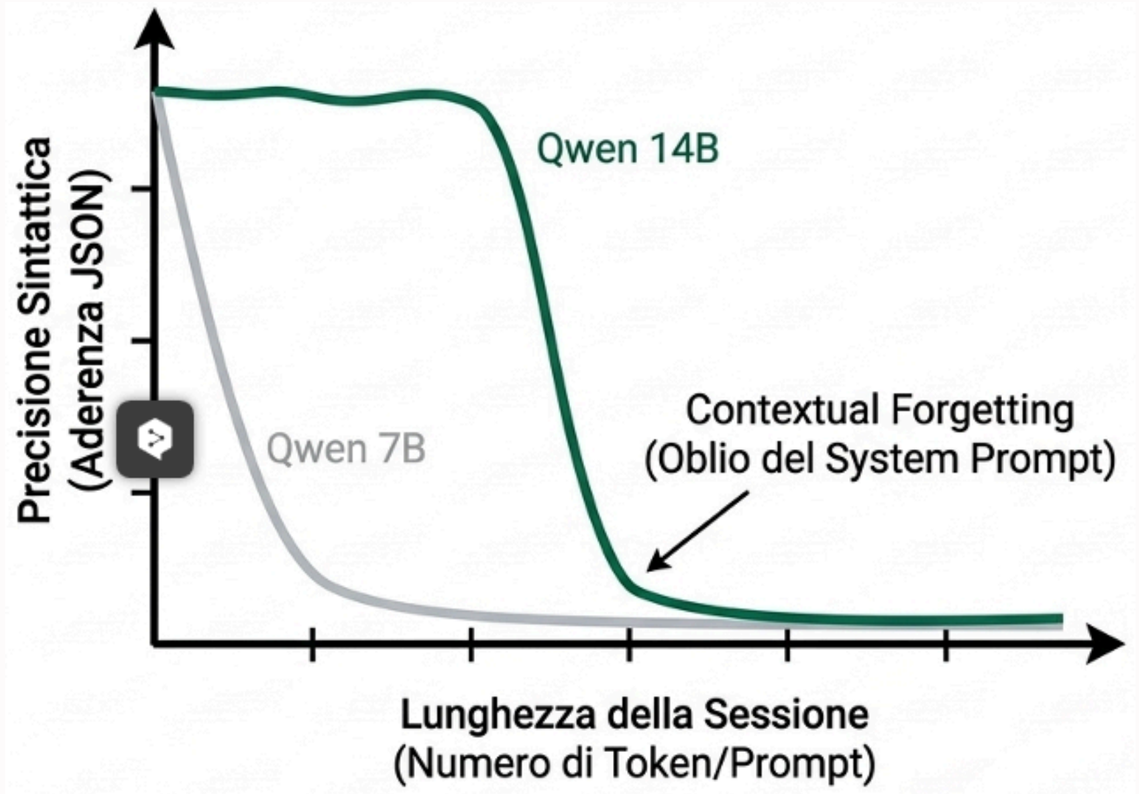
- **Sintomo:** Arresto immediato della scansione nelle fasi iniziali.
- **Causa Radice**: Deviazione dal formato JSON: il modello aggiunge testo libero o commenti non previsti.
- **Effetto:** Il parser dell'orchestratore fallisce l'interpretazione → eccezione non gestita e loop di tentativi.

```
You:
Identify and validate SQL injection, XSS, and broken authentication vulnerabilities on OWASP Juice Shop.

{"name": "exec_command", "arguments": {"cmd": "curl -s http://host.docker.internal:3000/health", "max_output_tokens": null, "shell": null, "tty": false, "workdir": null,
"yield_time_ms": 2000}}
```

Strix: JSON emesso come testo libero anziché invocazione API -> MaxTurnsExceeded

I Limiti Tecnici dei Modelli Locali On-Premise



Sintesi visiva del comportamento empirico osservato durante i test
NB. non sono punti campionati, ma uno schema qualitativo del degrado

La Trappola del Self-Correction

- Quando l'LLM sbaglia la sintassi, il framework reinvia l'errore chiedendo di correggere.
- Risultato: Il log di errore viene concatenato, 'avvelenando' il contesto e garantendo un loop di fallimento irreversibile.

Riproducibilità dell'Esperimento

Target: Isolamento OWASP Juice Shop

- docker run --network lab_internal -p 127.0.0.1:3000:3000 bkimminich/juice-shop

Binding vincolato al loopback per impedire esposizione alla LAN locale.

Risoluzione Rete: Bridge DNS

Il target risiede sulla rete isolata lab_internal, mentre l'accesso per i vari container degli agenti è stato instradato in modo pulito tramite host.docker.internal

Runtime: Ottimizzazione Modelli

Ollama eseguito nativamente sull'host per ottimizzare l'uso degli 8GB di VRAM.

```
costantino@DESKTOP-HG9HAK7:~/progetti/shannon$ cd ~/progetti/shannon

export SHANNON_AI_API_KEY=ollama
export SHANNON_AI_MODEL=ollama:qwen2.5-coder:7b

./shannon start \
  --url "http://host.docker.internal:3000" \
  --repo "$HOME/progetti/juice-shop-src-shannon-test" \
  --workspace "validate-qwen25-7b-screen" \
  --models-config "$PWD/configs/ollama_7b.json" \
  --validate-model

  Keygraph

  SHANNON

  AI Pentester for Web Apps and APIs

  -Authorized Security Testing Only-

◇  Validating model — validate-qwen25-7b-screen
  Target:     http://host.docker.internal:3000
  Repository: /home/costantino/progetti/juice-shop-src-shannon-test
  Workspace:  validate-qwen25-7b-screen
  Models:     /home/costantino/progetti/shannon/configs/ollama_7b.json
  Model:      ollama:qwen2.5-coder:7b

  Following validation log (Ctrl-C to stop watching):


================================================================================
Validation COMPLETED
────────────────────────────────────────

Workflow ID: validate-qwen25-7b-screen_shannon-1791373743229
Status:      completed
Duration:    12.1s
Total Cost:  $0.0000
Model:       ollama:qwen2.5-coder:7b

Checks:
  - Preflight (LLM credentials, target URL) — OK (11.6s)
  - Cyber access verification — not required for this provider
================================================================================
```

Conclusioni e Sviluppi Futuri

01

L'Illusione dell'Autonomia Pura

Per i modelli open-source di fascia consumer (7B/14B), il fully-autonomous "zero-click" si rivela architetturalmente immaturo a causa della fragilità nel tool-calling.

02

Il Paradigma Vincente

L'approccio più affidabile allo stato attuale è quello ibrido: l'IA fornisce la strategia e l'intuizione esplorativa, mentre l'operatore umano o scanner deterministici verificano e validano ciascuna azione sul campo.

03

Rischio Operativo & Etica

L'autonomia non mediata innalza i rischi di compliance, rendendo imprevedibile l'interazione con i sistemi target in ambienti reali.

04

Sviluppi Futuri

Necessaria l'implementazione sistemica di layer di 'Constrained Decoding' (es. Outlines/ Guidance) per forzare a livello engine il rispetto grammaticale dei JSON.

Dipartimento di Informatica



GRAZIE PER L'ATTENZIONE

Studente: Costantino Paciello
Docente: Prof. Arcangelo Castiglione
Anno accademico: 2025-26